LeBlanc
SOLUTIONS

WEBSITE SECURITY REPORT

M22 Detailing

m22detailing.com

A home inspection for your website — the common, fixable problems we found, in plain English, ranked by what matters.

Prepared by LeBlanc Solutions · 11 October 2026
Non-destructive external assessment · Authorised engagement

THE BOTTOM LINE

Good foundations. A handful of quick fixes will close the gaps.

1 medium · **2** low · **5** info — each with its fix, in the order that matters.

WHAT'S WORKING WELL

✓ **Your connection is properly locked**
Valid TLSv1.3 certificate from Let's Encrypt, renewing in 70 days.

✓ **Secret files are sealed off**
Sensitive paths like .env, .git and service-account keys all correctly refuse access (12 checked).

✓ **No outdated parts with known holes**
Your site's JavaScript components (jquery, jquery-migrate) are current, with no known published flaws.

✓ **Basic email protection is on**
SPF and a DMARC policy are configured, which helps stop others sending email as you.

YOUR TOP FIXES

1 **No shield against injected scripts**
Add a Content-Security-Policy. Roll it out in report-only mode first so nothing breaks, then switch it on.

2 **Your pages can be framed by a fake site**
Send an X-Frame-Options (or CSP frame-ancestors) header so other sites can't embed yours.

3 **Secure connection isn't strictly enforced**
Add a Strict-Transport-Security header so every visit is forced onto HTTPS.

WHAT WE FOUND

The full list, ranked

Most break-ins rely on the same handful of mistakes. Here's what we found on your site, worst first, each with what it means and how to close it.

MED

1. No shield against injected scripts

Like leaving the upstairs windows unlocked – anything that climbs in can walk around freely.

Your site doesn't tell the browser which scripts are allowed to run. A script slipped in through a plugin flaw or a third-party tag would execute on your pages — including your quote and contact forms.

THE FIX

Add a Content-Security-Policy. Roll it out in report-only mode first so nothing breaks, then switch it on.

LOW

2. Your pages can be framed by a fake site

Like someone taping a photo of your storefront over your real front door.

Without this setting, an attacker can load your site inside their own page and trick visitors into clicking things they can't see.

THE FIX

Send an X-Frame-Options (or CSP frame-ancestors) header so other sites can't embed yours.

LOW

3. Secure connection isn't strictly enforced

Like a good lock on a door that can still be nudged open on the very first push.

The padlock works, but a visitor's first request can be downgraded to an unencrypted connection on shared Wi-Fi before the secure one kicks in.

THE FIX

Add a Strict-Transport-Security header so every visit is forced onto HTTPS.

INFO

4. Visitor trails can leak to other sites

Like handing a stranger a note of exactly where your customer just came from.

Internal page addresses can be passed along to third-party sites as visitors click outbound links.

THE FIX

Set a Referrer-Policy header to limit what's shared.

INFO

5. Browser features left switched on

Like leaving every appliance plugged in and running when you only use one.

Camera, location and other browser features aren't restricted, widening what a malicious script could try to reach.

THE FIX

Add a Permissions-Policy header that only allows the features you actually use.

INFO

6. Your admin door opens onto the public street

Like a shop's back-office door opening straight onto a busy sidewalk.

Your WordPress login page is reachable by anyone on the internet, so automated bots can sit there trying password after password.

THE FIX

Add login rate-limiting and two-factor sign-in, and consider moving the login to a non-obvious address.

INFO

7. A form endpoint worth double-checking

Like a mail slot you should make sure only accepts letters, not anything shoved through it.

This address accepts input (such as a name and an attachment). It's worth confirming it rejects anything unexpected and limits file uploads. Affected: /api/me, /api/feedback.

THE FIX

Validate and sanitise the inputs, and cap file type and size on any upload.

INFO

8. Look-alike email from your subdomains

Like someone printing letterhead with your address on it and mailing it out.

Your main domain is protected against spoofing, but mail sent from your subdomains isn't — so it can be forged in your name.

THE FIX

Tighten your DMARC record so subdomains are covered by the same quarantine policy.

LeBlanc
SOLUTIONS

WHAT HAPPENS NEXT

You fix, we re-check

Work down the ranked list. When you're done, tell us and we scan again to confirm each item is actually closed — so you can see the before and after.

Prefer we handle it? We also implement the fixes for you, and can redesign the site to be secure from the ground up.

Get in touch · **contact@leblancsols.com**

This report finds common, fixable problems so you can close them before someone else finds them. It is not a guarantee against every possible attack, a full manual penetration test, or a compliance certificate. We test only sites you own or are authorised to test.

© 2026 LeBlanc Solutions